

BLUE BANDS COLLECTORS

The invoice looks right. Does the payment?

RenderGuard

An evidence-bound release gate for AI-prepared repeat-supplier
EUR payments.

Viktor Vitovec / Jan Sebastian Rosicky / Krystof Bigas

LIVE DEMO

<https://renderguard.vvitovec.com>

<https://github.com/vvitovec/RenderGuard>

SANDBOX ONLY

No bank connected. No money moved.

THE SPECIFIC FAILURE

One invoice can carry two payment instructions.

User: an accounts-payable operator preparing a repeat-supplier payment against an approved purchase order.

Visible page

Account ...1001

EUR 1,240.00

Hidden PDF text / QR

Account ...9999

Same-looking invoice

Approved supplier

Account ...1001

Independent authority

Payment changes must be independently verified using a saved supplier contact. Document agreement alone cannot authorize a new bank account.

Research: FBI business email compromise guidance; Microsoft vendor-bank approval workflow.

PURPOSE-BUILT WORKFLOW

AI prepares. Independent evidence decides.

01	02	03	04	05
Select authority	Establish evidence	Constrain the AI	Approve exact intent	Release once
Approved repeat supplier + PO	Raster / OCR / PDF text / EPC QR	Semantic guard + bank handles	Reviewer-bound action + evidence	Protected sandbox ledger receipt

Bank verification is a separate administrator workflow. The assistant cannot change supplier authority, approve itself or execute a payment.

A COMPLETE POSITIVE PATH

A legitimate invoice reaches a saved receipt.

Actual rendered PDF -> local model proposal -> human reviewer -> immutable sandbox ledger.

The AI receives opaque account handles
and evidence-grounded structured fields.

The reviewer sees the exact recipient, EUR amount,
invoice and approved obligation.

Execution rechecks authority and records one
receipt. A retry returns that same receipt.

CONCRETE ADVERSARIAL EVIDENCE

The page and the payment QR disagree.

The actual QR-swap PDF is blocked before any model dispatch.

Visible recipient: ...1001. Decoded EPC
recipient: ...9999. Approved supplier:
...1001.

Also tested: hidden text recipient / total, QR
amount swap, unverified account change,
ambiguity and overbilling.

HYBRID CONTROL LAYER

Deterministic authority. Semantic interpretation.

DETERMINISTIC RELEASE CONTROLS

Identity, models, tools, privacy patterns, literal attack signatures, evidence agreement, supplier/PO, action schema and budget reservations.

REAL LOCAL SEMANTIC GUARD

Qwen2.5:3b classifies behavioral overrides in untrusted document content. The proposal model is constrained to evidence-grounded fields.

Policy and literal signature catalog can be edited live. Historical probes inspect CVE-2025-6514 unsafe MCP authorization endpoints and unsafe pickle formats; they never execute supplied code.

PROTECTED EXECUTION

An approval means one exact action.

- Payment hash
- Source PDF + rendered-image hashes
- Structured evidence hash
- Approved supplier + obligation hashes
- Policy version + signature catalog
- Workspace, reviewer capability and expiry

A change invalidates the approval.

A single transaction revalidates, consumes approval and inserts the receipt. Unique proposal / invoice constraints prevent duplicate effects.

8 concurrent retries -> 1 receipt

Executable concurrency test; actual SQLite ledger.

REPORTING AND RESOURCE CONTROL

Show the decision. *Account for the cost.*

Actual decision trail, policy versions, model tokens, stage latency, bound hashes and immutable receipts.

Export redacted JSONL and sandbox release CSV.
Approval tokens never enter exports.

Reserve call / token / cost / concurrency limits before dispatch. Unknown interrupted usage consumes its reservation.

REPRODUCIBLE EVIDENCE

Positive cases matter as much as attacks.

Finite synthetic corpus and stated prompts. No universal fraud or prompt-injection guarantee.

65/65

9/14

6/6

0/0

Control / integration checks

Full live PDF workflows

Real semantic prompt checks

Headless browser workflows

Actual OCR + labelled provider double

Real local AI, worker, approval, release

Benign terms and behavioral overrides

No mocked network; desktop + mobile

Evidence-only raster/OCR corpus: 14/14; seven legitimate variants + seven blocked cases.

Recorded reports include source-content hashes; commands and expected cases are packaged.

READY TO INSPECT AND CHANGE

A complete gate, with an explicit boundary.

Robustness: exact protected release and adversarial checks.

Architecture: isolated worker, modular gateway and provider. Reporting: actual audit and export. Tests: executable positive and negative suite.

Scale: bounded resources and a documented migration path.

Deployed on always-on hosts. No paid key required. Team and submission materials are fully English.

<https://renderguard.vvitovec.com>

SUPPORTED

Repeat supplier / approved EUR obligation / labelled PDF / EPC QR / sandbox ledger.

PRODUCTION INTEGRATION

External identity, independently managed ERP authority, disposable workers and an idempotent bank adapter.